ФГБОУ ВО «Московский технологический университет»
Институт кибербезопасности и цифровых технологий

Кафедра КБ-1 «Защита информации»

Дисциплина: «Разработка и эксплуатация автоматизированных систем в защищенном исполнении»

Отчет по лабораторной работе №2

Тема: Применение стандарта функционального моделирования для построения модели предметной области (модели «as-is», «to-do»)

Вариант задания №10

Выполнил:
Студент группы БАСО-04-22
Кузнецов Алексей Александрович

Проверил:
доцент Федин Ф.О

Москва
2025

Учебная цель занятия: Углубить теоретические знания и выработать практические умения в области применения стандарта функционального моделирования деловых процессов.

Место проведения занятия: компьютерная аудитория.

Учебно-материальное обеспечение:

1) Методические указания.

2) Автоматизированное рабочее место в компьютерном классе.

3) Инструментальное CASE-средство CA ERWin Process Modeler.

Задание №1. Для предметной области своего варианта (варианты автоматизированных систем в защищенном исполнении были даны ранее), в инструментальном средстве CA ERWin Process Modeler, с применением стандарта функционального моделирования IDEF0, самостоятельно построить (точка зрения – сотрудника службы ИБ) и описать:

– контекстную диаграмму верхнего уровня модели функционирования одного из наиболее значимых процессов (модель «как есть»);

– диаграмму декомпозиции контекстной диаграммы верхнего уровня;

– диаграмму декомпозиции одной из работ (декомпозируемую работу выбрать самостоятельно).

Ход выполнения задания

Тема варианта задания №10: «Разработка защищенной автоматизированной информационной системы учета кадров маркетинговой компании».

Рассматриваемая компания: общество с ограниченной ответственностью “Маркетинг с умом”, предоставляющее различные услуги в области маркетинга, в том числе развитие брендов заказчиков, улучшение их узнаваемости на рынке среди конкурентов.

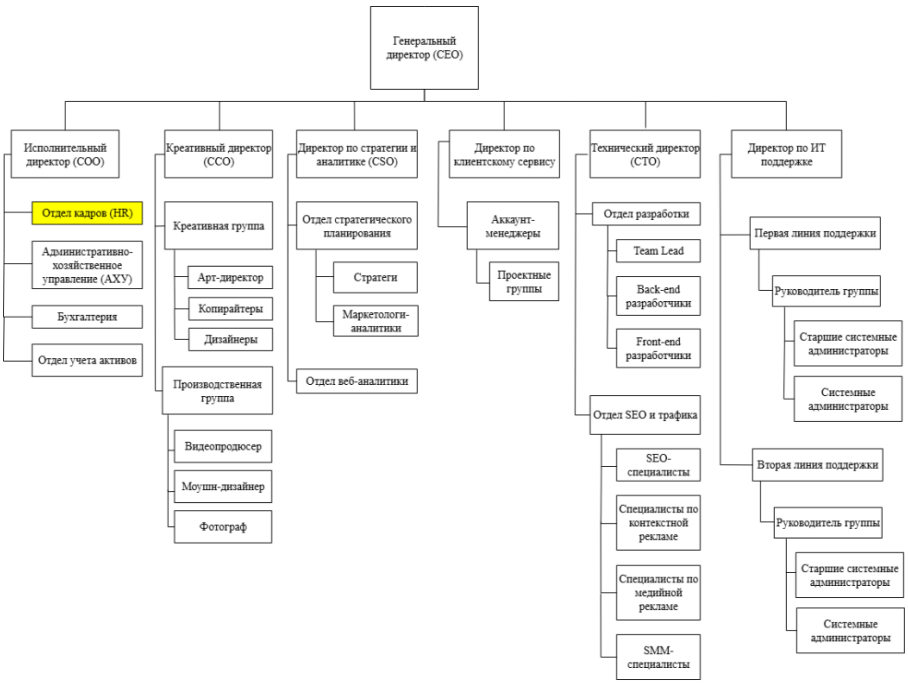


Рисунок 1 – Организационно-структурная схема компании

Построим модель деятельности предприятия “как есть” для процесса трудоустройства утвержденного кандидата. В компании не представлено автоматизированной информационной системы, в которой обрабатывалась бы информация. Работа с различными данным ведется посредством записи в бумажные журналы и использования офисных пакетов операционной системы Windows.

Утвержденным кандидатом будем считать человека, который успешно прошел собеседование, и компания готова его трудоустроить. Для этого необходимо подготовить пропуск сотрудника, выдать права доступа к определенным помещениям, подготовить учетную запись с применением различных политик для работы с ОС, подготовить автоматизированное рабочее место, выделить бюджетные средства из плана на выплату зарплаты.

После выполнения указанных шагов менеджер по подбору персонала связывается с утвержденным кандидатом для обсуждения даты первого рабочего дня.

В соответствии со стандартом IDEF0 создаваемая модель функционирования определяется как совокупность иерархически

упорядоченных и взаимосвязанных диаграмм, а также описаний их элементов с помощью словарей.

Функциональный блок (Activity Box) графически изображается в виде прямоугольника и олицетворяет собой некоторую конкретную функцию в рамках рассматриваемой системы. По требованиям стандарта каждый функциональный блок имеет уникальный номер, а его имя должно быть выражено оборотом глагола в повелительном наклонении (например, «Заполнить опросный лист», а не «Заполнение опросного листа»).

Каждая из четырех сторон функционального блока имеет своё определенное значение (роль), при этом:

– верхняя сторона имеет значение «Управление» (Control);

– левая сторона имеет значение «Вход» (Input);

– правая сторона имеет значение «Выход» (Output);

– нижняя сторона имеет значение «Механизм» (Mechanism).

Интерфейсная дуга (стрелка) (Arrow) отображает элемент системы, который обрабатывается функциональным блоком или оказывает иное влияние на функцию, отображенную данным функциональным блоком. По требованиям стандарта каждая стрелка именуется существительным или именными словосочетаниями (например, «Сообщение», «Уведомление», «Опросный лист» и пр.)

Каждая интерфейсная дуга:

– обладает уникальным наименованием (Arrow Label), выраженным оборотом существительного;

– имеет тип: входящая, исходящая, управляющая или механизм реализации;

– отображает объекты реального мира или потоки данных и информации.

Графическим отображением интерфейсной дуги является однонаправленная стрелка.

Декомпозиция позволяет постепенно и структурированно представлять модель функционирования системы в виде иерархической структуры отдельных диаграмм, что делает ее менее перегруженной и легко усваиваемой.

Модель IDEF0 всегда начинается с представления системы как единого целого – одного функционального блока с интерфейсными дугами, простирающимися за пределы рассматриваемой области (граничные стрелки). Такая диаграмма с одним функциональным блоком называется контекстной диаграммой и обозначается идентификатором «A-0» (А минус ноль).

В процессе декомпозиции, функциональный блок, который в контекстной диаграмме отображает систему как единое целое, подвергается детализации на другой диаграмме. Получившаяся диаграмма второго уровня содержит функциональные блоки, отображающие главные подфункции функционального блока контекстной диаграммы и называется дочерней (Child diagram) по отношению к нему (каждый из функциональных блоков, принадлежащих дочерней диаграмме, соответственно, называется дочерним блоком – Child Box). В свою очередь, функциональный блок – предок называется родительским блоком по отношению к дочерней диаграмме (Parent Box), а диаграмма, к которой он принадлежит – родительской диаграммой (Parent Diagram). Каждая из подфункций дочерней диаграммы может быть далее детализирована путем аналогичной декомпозиции соответствующего ей функционального блока. Важно отметить, что в каждом случае декомпозиции функционального блока все интерфейсные дуги, входящие в данный блок, или исходящие из него фиксируются на дочерней диаграмме. Этим достигается структурная целостность IDEF0-модели.

Процесс декомпозиции продолжается до тех пор, пока объект не будет описан на уровне детализации, необходимом для достижения целей конкретного проекта.

В глоссарии (словаре) содержится подробное описание каждого элемента диаграммы: определения, ключевые слова, повествовательные изложения и т.д. Глоссарий гармонично дополняет наглядный графический язык, снабжая диаграммы необходимой дополнительной информацией.

Необходимые исходные данные для осуществления процесса трудоустройства утвержденного кандидата (входные стрелки слева): данные кандидата, запросы в бухгалтерию, АХУ и ИТ, а также данные аутентификации в ОС.

Результаты деятельности по процессу трудоустройства утвержденного кандидата следующие (выходные стрелки справа): трудоустроенный сотрудник.

Управляющие механизмы (стрелки сверху):

– Федеральные законы № 152-ФЗ “О персональных данных” и № 149-ФЗ “Об информации информационных технологиях и о защите информации”;

– Трудовой кодекс РФ.

– Внутренние нормативно-правовые акты компании. К ним относятся:

1. Инструкция о мерах пожарной безопасности
2. Приказ “О защите информации, составляющей коммерческую тайну”
3. Политика информационной безопасности
4. Политика соблюдения антикоррупционного законодательства
5. Приказ об утверждении Положения О порядке работы с системами, обрабатывающими пользовательские данные
6. Положение О порядке работы с системами, обрабатывающими пользовательские данные
7. Положение о командировках сотрудников
8. Политика по управлению интеллектуальной собственностью
9. Положение об оплате труда
10. Правила внутреннего трудового распорядка

11. Положение о персональном учете на предприятии

12. Политика в области охраны труда

13. Положение о пропускном и внутриобъектовом режиме

14. Приказ об утверждении процедуры электронного документооборота с сотрудниками

Исполнительные механизмы (стрелки снизу): начальник отдела кадров, менеджер по подбору кандидатов, утвержденный кандидат.

Итоговая контекстная диаграмма верхнего уровня имеет вид, представленный на рисунке 2.

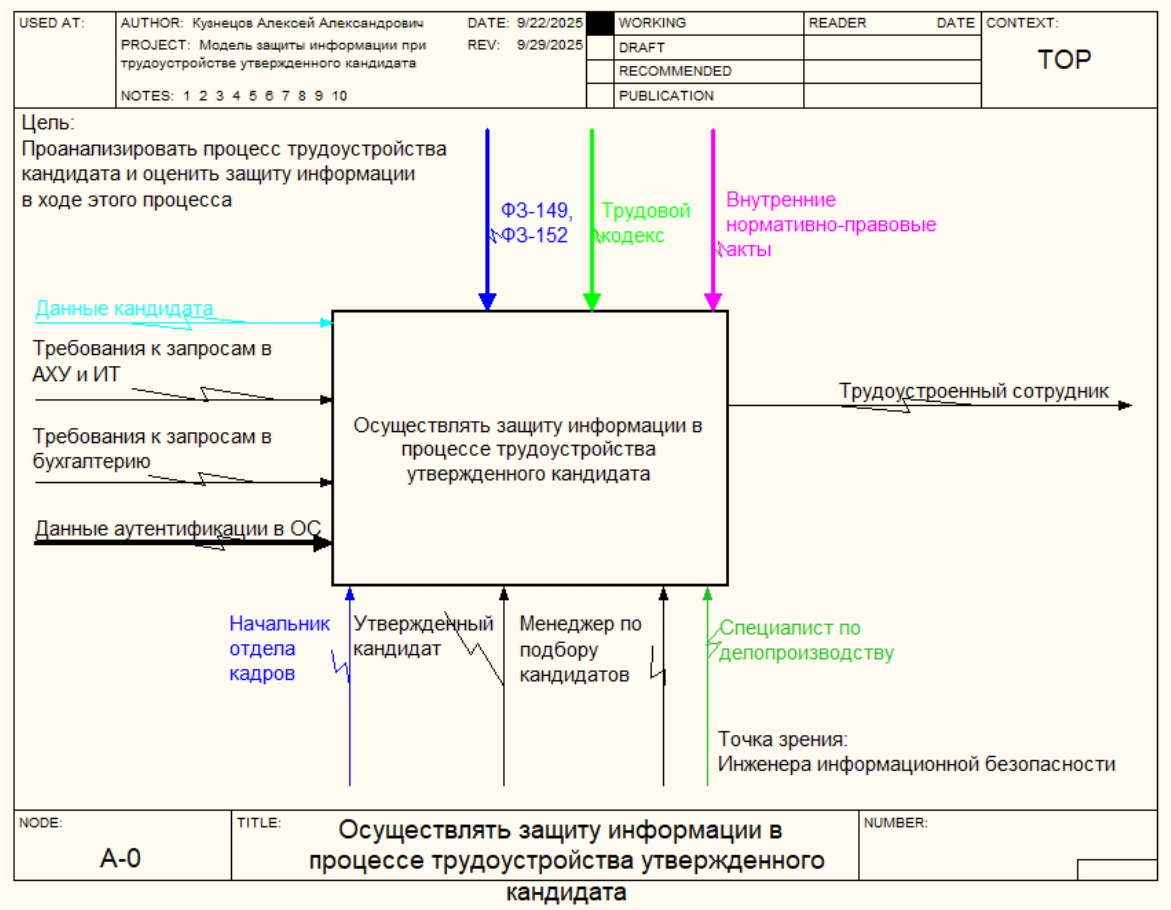


Рисунок 2 – Контекстная диаграмма модели осуществления ЗИ в процессе трудоустройства утвержденного кандидата

Декомпозиция – это разделение сложного объекта, системы, задачи на составные части, элементы.

С помощью диаграммы декомпозиции первого уровня покажем, из каких более мелких работ состоит работа «Осуществлять ЗИ в процессе трудоустройства утвержденного кандидата». Все эти более мелкие работы были выявлены в результате исследования предметной области – деятельности отдела кадров маркетинговой компании.

Для получения диаграммы детализации центральный функциональный блок контекстной диаграммы верхнего уровня был декомпозирован. В результате была сформирована контекстная диаграмма декомпозиции уровня А0 (рисунок 3).

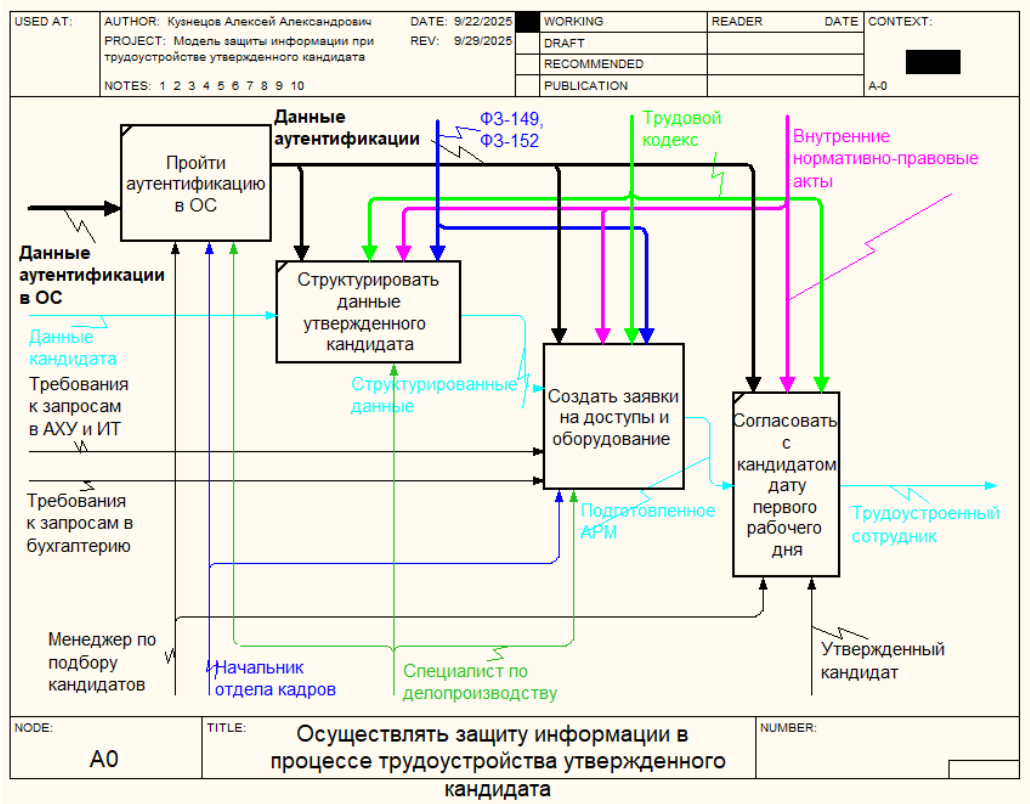


Рисунок 3 - Контекстная диаграмма уровня А0

Основные деловые процессы (рисунок 3):

– Выполнить аутентификацию в операционной системе;

– Структурировать данные утвержденного кандидата;

– Создать заявки на доступы и оборудование;

– Согласовать с кандидатом дату первого рабочего дня.

Анализ процесса выполнения аутентификации сотрудников отдела кадров в операционной системе своего компьютера показал, что аутентификация является парольной, однофакторной. Пользователь, который правильно введет логин и пароль, получает беспрепятственный доступ к имеющимся данным, включая персональные данные кандидатов.

Такой способ однофакторной парольной аутентификации имеет ряд недостатков:

– пользователи, благодаря собственной беспечности, могут применять пароли, которые можно легко угадать или подобрать (отсутствует парольная политика);

– логин и пароль могут быть перехвачены или подсмотрены в процессе его ввода;

– логин и пароль можно получить от владельца путем его подкупа или шантажа и др.

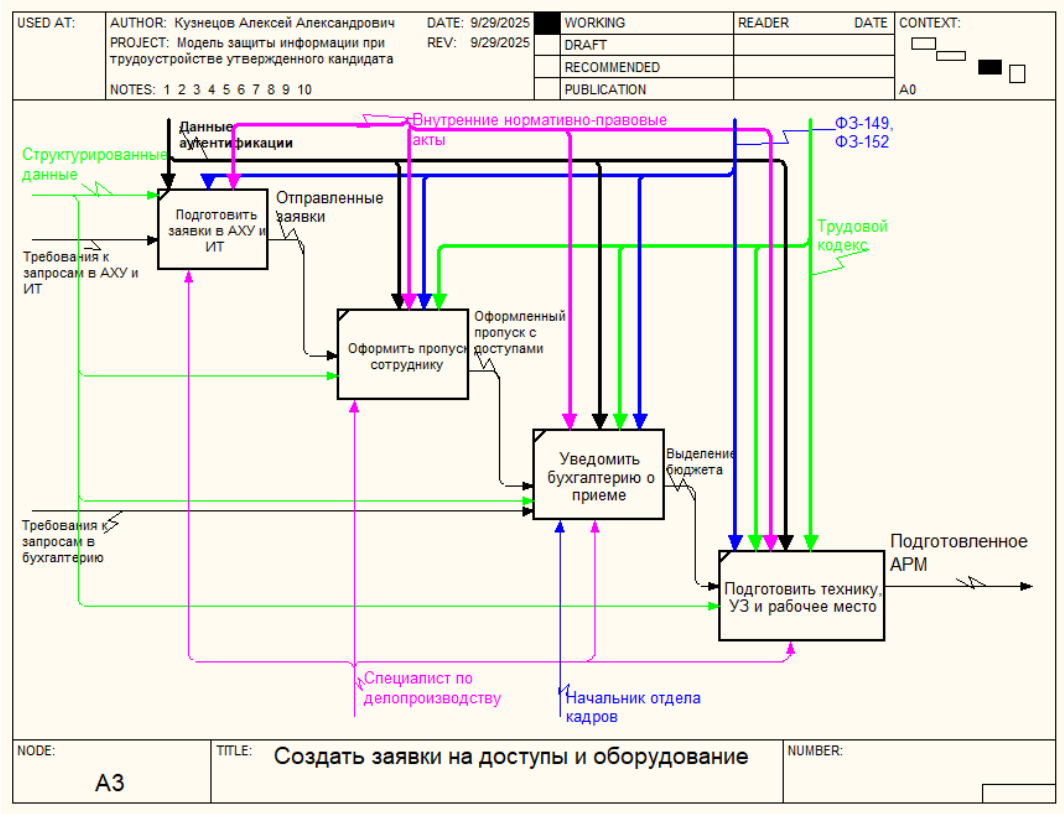


Рисунок 4 – Диаграмма декомпозиции работы “создать заявки на доступы и оборудование”

Диаграмма декомпозиции работы “создать заявки на доступы и оборудование” представлена на рисунке 4. В модели “как есть” заявки подготавливаются с использованием электронной почты, отчетность ведется в бумажном журнале. Коммуникации ведутся лично или с помощью электронной почты. Специалист по делопроизводству совместно с коллегами из ИТ оформляет пропуск с необходимыми доступами в помещения. После данных приготовлений в бухгалтерию направляется письмо о приеме кандидата на работу, начальник отдела кадров согласует данное письмо. Далее усилиями сотрудников ИТ и АХУ создается учетная запись, подготавливается техника для рабочего места, результаты сообщаются специалисту по делопроизводству, который впоследствии передает информацию о готовности рабочего места менеджеру по подбору кандидатов.

Задание №2. Для предметной области своего варианта, в инструментальном средстве CA ERWin Process Modeler, с применением стандарта функционального моделирования IDEF0, самостоятельно построить (точка зрения – сотрудника службы ИБ) и описать:

– контекстную диаграмму верхнего уровня модели функционирования одного из наиболее значимых процессов (модель «как будет»);

– диаграмму декомпозиции контекстной диаграммы верхнего уровня;

– диаграмму декомпозиции одной из работ (декомпозируемую работу выбрать самостоятельно).

Ход выполнения задания

Для модели “как будет” учтем обнаруженные недостатки и внедрим автоматизированную систему в защищенном исполнении. Для доступа к персональным данным требуется пройти двухфакторную аутентификацию:

1. Аутентификация в ОС и СУБД с паролем, подходящим по требованиям парольной политики (пароль длиннее 12 символов, содержит буквы верхнего и нижнего регистра, специальные символы, цифры, должен обновляться каждые 3 месяца и не должен быть похожим не предыдущие 12 паролей).
2. Второй фактор в виде аппаратного исполнения: токен или смарт-карта с сертификатом сотрудника, защищенным пин-кодом (минимум 8 символов). Например, это может быть Рутокен или JaCarta. Таким образом будет значительно усложнен несанкционированный доступ к защищаемой информации, так как токен находится исключительно у обладающего им сотрудника.

Все персональные данные циркулируют в автоматизированной информационной системе с подключенной реляционной БД, где также можно создавать запросы в другие отделы (например, подготовка и предоставление ИТ оборудования).

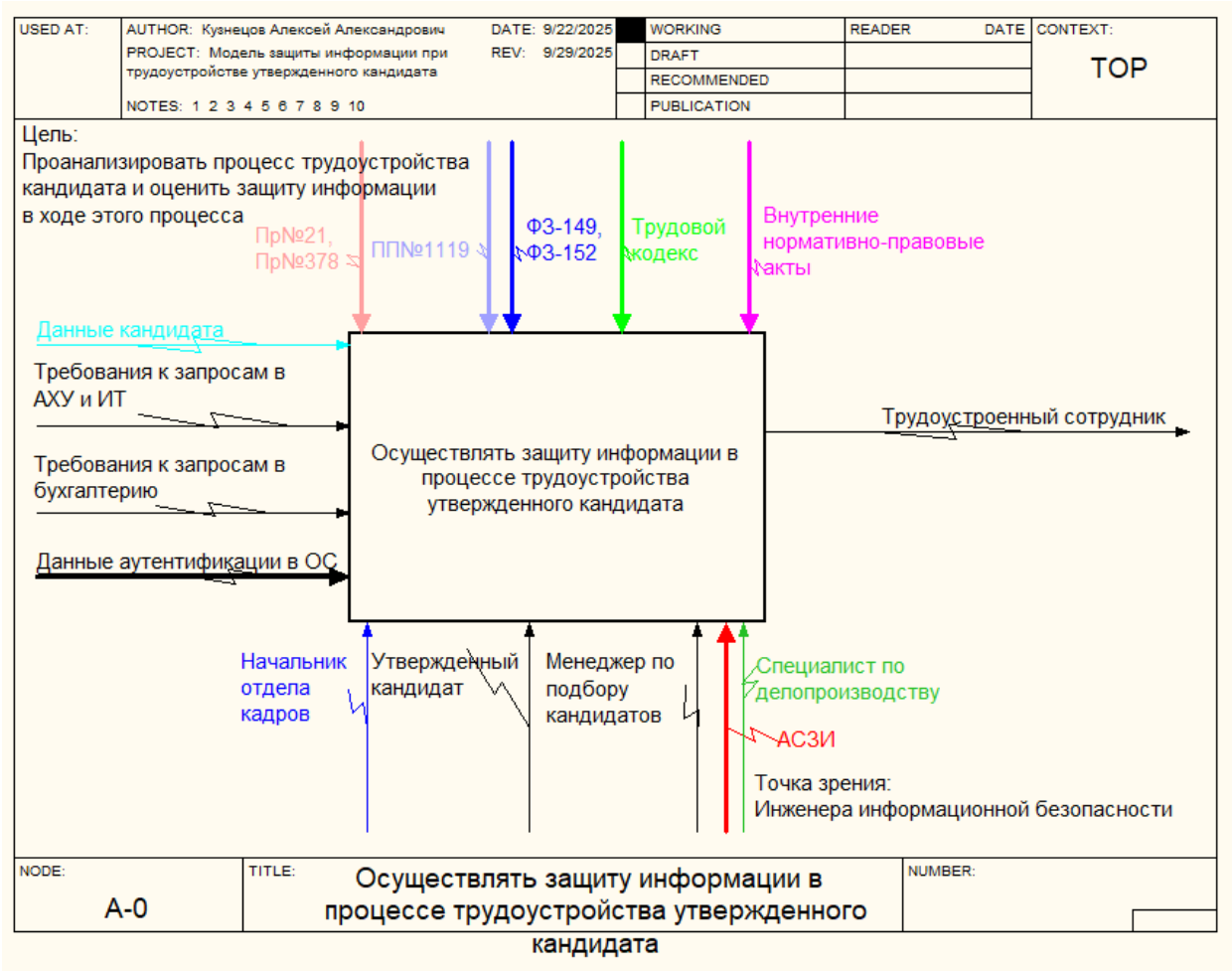


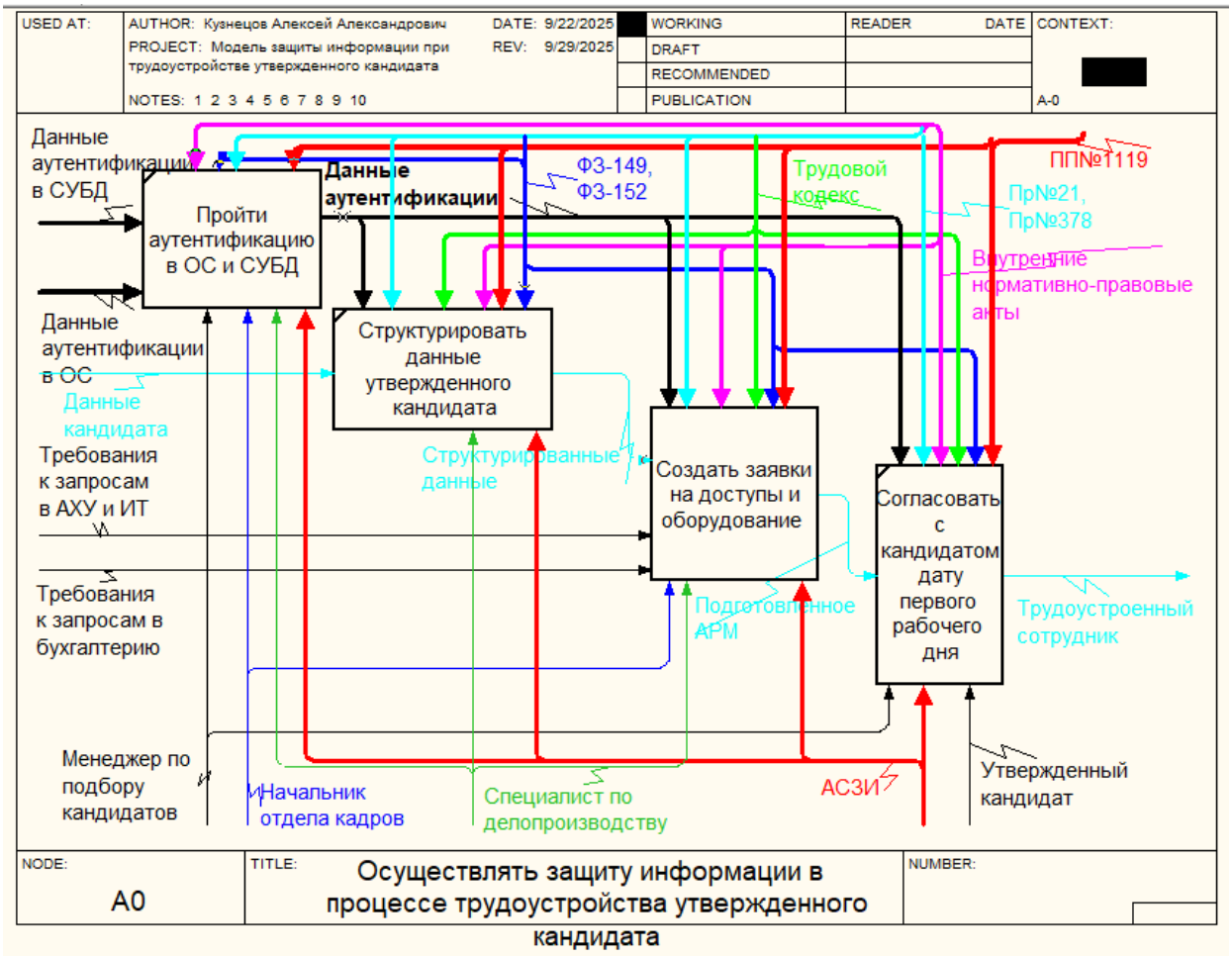
Рисунок 5 - Контекстная диаграмма модели осуществления ЗИ в процессе трудоустройства утвержденного кандидата (модель “как будет”)

Также к управляющим механизмам добавились следующие документы:

Приказ ФСТЭК России от 18.02.2013 №21, который утверждает состав и содержание организационных и технических мер по обеспечению безопасности ПДн.

Приказ ФСБ России от 10.07.2014 №378, который определяет состав и содержание организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием СКЗИ, необходимых для выполнения требований к защите персональных данных для каждого из уровней защищенности.

Постановление Правительства № 1119 устанавливает требования к защите персональных данных при их обработке в информационных системах персональных данных (ИСПДн) и уровни защищенности таких данных.


USED AT:
AUTHOR: Кузнецов Алексей Александрович
DATE: 9/22/2025
PROJECT: Модель защиты информации при трудоустройстве утвержденного кандидата
REV: 9/29/2025
NOTES: 1 2 3 4 5 6 7 8 9 10
WORKING
DRAFT
RECOMMENDED
PUBLICATION
READER
DATE
CONTEXT:
A-0
Данные аутентификации в СУБД
Пройти аутентификацию в ОС и СУБД
Данные аутентификации
ФЗ-149, ФЗ-152
Трудовой кодекс
ППП№1119
ПрПрПр

Заявка, созданная в АИС, автоматически направляется ответственным и после согласования исполняется, а не является просто уведомлением.

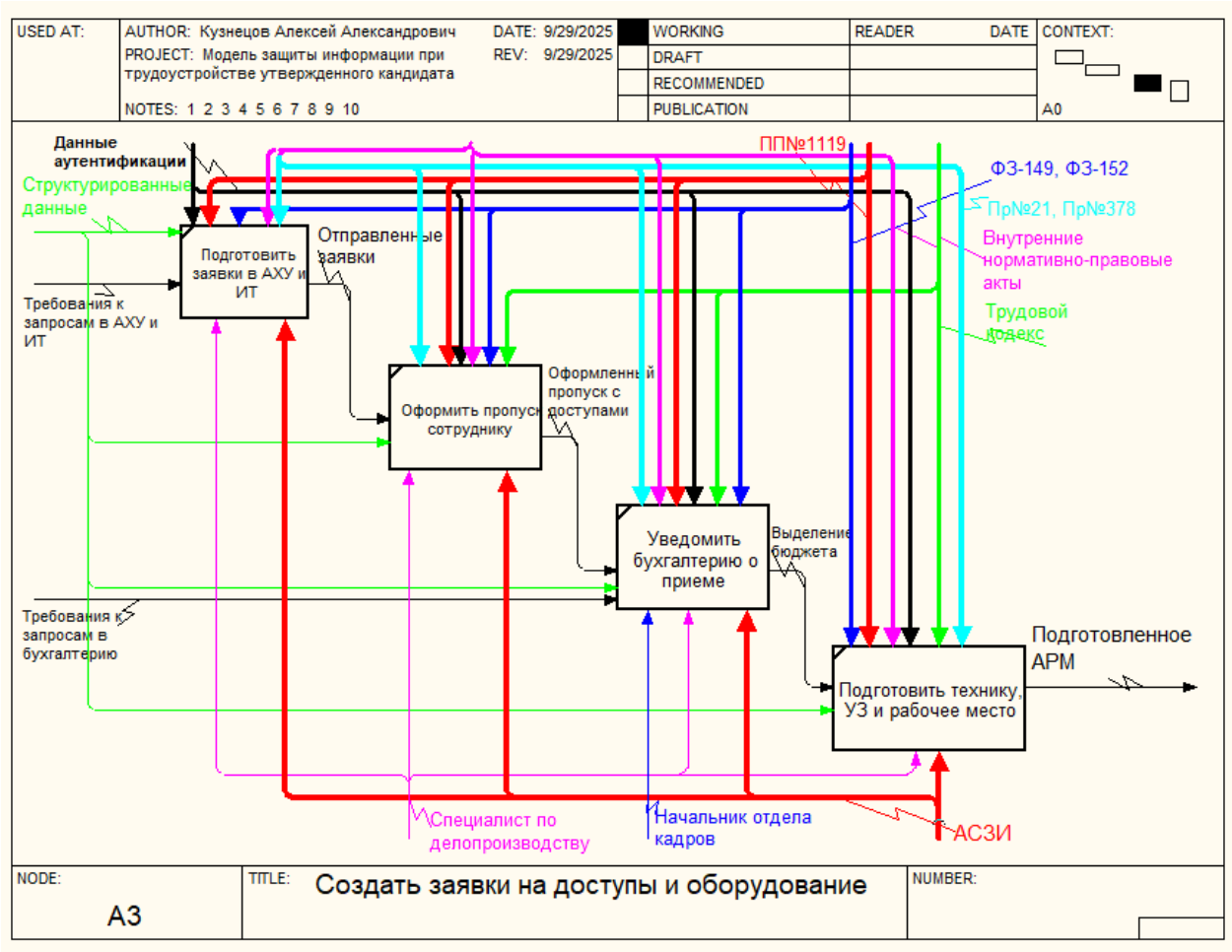


Рисунок 7 - Диаграмма декомпозиции работы “создать заявки на доступы и оборудование” модели “как будет”

Выводы по проделанной работе

В результате выполнения лабораторной работы были решены следующие задачи:

- успешно применен стандарт IDEF0 для построения двух контрастных моделей, проведена декомпозиция процессов, проанализированы и отображены входы, выходы, управления и механизмы.

- выработаны навыки анализа предметной области, выявления узких мест и проектирования целевого состояния процесса с позиции сотрудника службы ИБ.

- получены практические навыки работы в инструментальном средстве CA ERWin Process Modeler.